

Manual 15 - Implementação Controlada de SOC 2

Authority boundary: original implementation guidance. SOC 2 is an independent CPA attestation examination, not a certification.

Localized editions are controlled implementation translations and are not AICPA-authorized translations. The controlled English edition governs interpretation.

Manual 15 — Localization and Artifact Handoff

****State:**** controlled pre-publication preparation; not publication authorization

****Series order:**** 15

****Controlling English source blob:****
`92bd8eb8b51dbd1367e4968eaf3fad1b399af5d9`

****Controlling source:****
`English/source/CONTROLLED\_CHAPTERS\_01\_32.md`

Objective

Move Manual 15 from completed controlled English source into exact-source localization and publication-candidate preparation without changing the authoritative interpretation boundary or fabricating human semantic review.

Exact-source rule

All es-419 and pt-BR localized drafts must derive from the English source blob identified above. If the English source changes materially, localization parity and all downstream artifact hashes are invalidated and must be regenerated from the new exact source.

English remains the controlling interpretation. Localized editions are implementation translations and must not be described as AICPA-authorized or official translations.

Mandatory terminology boundaries

Preserve these distinctions in both localized editions:

- SOC 2 is an independent CPA attestation examination/reporting engagement, not a certification.
- Trust Services Criteria and Description Criteria are separate controlled concepts.
- Management owns the system description, assertion, controls, evidence and remediation; the independent practitioner owns examination procedures, professional judgment, opinion and report issuance.
- Type 1 and Type 2 readiness must remain distinct.
- Security, availability, processing integrity, confidentiality and privacy must remain separate categories where applicable.
- Complementary user-entity controls and subservice-organization responsibilities must not be collapsed into service-organization controls.
- Readiness assistance must never be represented as replacing independent CPA judgment.

es-419 controlled-draft requirements

Use professional Latin American Spanish suitable for GRC, audit, privacy, security and executive readers. Retain `SOC 2`, `Trust Services Criteria`, `Description Criteria`, `Type 1`, `Type 2` and other formal identifiers where translation could imply a different official term. Use consistent controlled equivalents for system description, assertion, service organization, subservice organization, complementary user-entity controls, evidence population, operating effectiveness, exception, remediation and reassessment.

The es-419 draft may be machine-assisted, but substantive semantic acceptance must be recorded separately if repository policy requires genuine human judgment.

pt-BR controlled-draft requirements

Use professional Brazilian Portuguese suitable for GRC, auditoria, privacidade, segurança and executive readers. Retain formal SOC identifiers where translating them could imply an official AICPA translation. Use consistent controlled equivalents for system description, assertion, service organization, subservice organization, complementary user-entity controls, evidence population, operating effectiveness, exception, remediation and reassessment.

The pt-BR draft may be machine-assisted, but substantive semantic acceptance must be recorded separately if repository policy requires genuine human judgment.

Parity QA

Before artifact generation, fail closed unless all three editions satisfy:

1. exactly 32 chapters in identical order;
2. equivalent chapter purpose and control/evidence intent;
3. no dropped management/practitioner independence boundary;
4. no new certification, endorsement or legal-compliance claim introduced by translation;
5. no omission of owners, frequencies/triggers, populations, evidence, exceptions/remediation or reassessment concepts where present in English;
6. no stale source lineage;
7. no protected AICPA criteria text reproduced beyond permissible use.

Publication-candidate generation

After trilingual source/parity QA, generate six candidate binaries from the exact controlled sources:

- EN DOCX and PDF;
- es-419 DOCX and PDF;
- pt-BR DOCX and PDF.

The generator must create reproducible metadata, language tags, headings, page numbering, controlled-use notice and source/provenance references. PDFs must undergo text-content preflight and rendered accessibility/visual review. DOCX/PDF files must not be resaved after SHA-256 binding.

Provenance and durability

For each candidate record:

- source path and source blob/commit;
- artifact path;
- SHA-256;
- generation workflow/run identifier;
- page/content QA result;
- accessibility/visual result;
- terminology/parity result;
- review evidence required by repository policy;
- predecessor publication state.

Validated binaries must then be durably staged to the repository without regeneration. Catalog and work-product release-registry changes occur only after all publication gates are satisfied.

Current blocker boundary

Manual 14 is published, so predecessor order is satisfied. Manual 15 is not publication-eligible until controlled es-419 and pt-BR editions, exact candidate artifacts, rendered/accessibility QA, checksum/provenance, durable artifact staging, and any explicitly required genuine-human substantive reviews are complete. Standing Final Human Release Approval remains separate and does not substitute for genuine-human review where repository policy explicitly requires it.

Manual 15 — Implementação Controlada de SOC 2

Aviso de uso controlado

Este manual é um guia original de implementação e preparação. Não reproduz os Trust Services Criteria, os Description Criteria, guias pagos, relatórios ilustrativos nem material reservado a profissionais da AICPA. SOC 2 é um exame de atestação independente realizado por um CPA; não é uma certificação. A administração é responsável pelo sistema, controles, descrição do sistema, afirmações, evidências e remediação; o profissional independente é responsável pelos julgamentos do exame e pelo relatório.

Esta edição é uma tradução controlada de implementação em português do Brasil (pt-BR) e não é uma tradução oficial nem autorizada pela AICPA. A edição controlada em inglês prevalece para fins de interpretação.

Chapter 01 — Propósito, público e contexto do trabalho

Use este manual para estabelecer um modelo repetível de prontidão SOC 2 e de operação de controles e evidências. Defina necessidade de negócio, usuários previstos, serviços, cronograma, tipo provável de relatório e categorias relevantes de Trust Services. Nomeie patrocinador executivo, líder de prontidão, responsável pela descrição do sistema, proprietários de controles, provedores de evidências, responsáveis por remediação e partes interessadas jurídicas, de privacidade e tecnologia.

Mantenha requisito de negócio, termo de prontidão, RACI, marcos, critérios de seleção do auditor, registro de decisões e o limite documentado entre apoio à prontidão e julgamento independente do CPA.

Chapter 02 — Limite da organização de serviços e definição do sistema

Defina a organização de serviços e o sistema que entrega os serviços em escopo. Identifique infraestrutura, software, dados, pessoas, procedimentos, locais físicos, serviços em nuvem, processos de desenvolvimento e suporte, identidades, monitoramento e terceiros materiais.

Mantenha declaração de escopo, inventário de componentes, diagramas de arquitetura e fluxo de dados, catálogo de serviços, registros de propriedade,

mapa de dependências e reavaliação acionada por mudanças. Toda exclusão deve ter justificativa documentada e análise de impacto.

Chapter 03 — Responsabilidades da administração e afirmação

A administração é responsável por desenhar, implementar, operar, monitorar e descrever os controles e por fazer as representações exigidas no trabalho. Atribua executivos responsáveis e proprietários operacionais de controles e defina responsabilidades de evidência.

Não delegue a responsabilidade da administração ao consultor de prontidão nem ao auditor de serviços. Preserve aprovações, representações da administração, atestações de proprietários de controles, decisões sobre problemas e evidências de entendimento do ambiente de controle.

Chapter 04 — Descrição do sistema e prontidão frente aos Description Criteria

Construa a descrição do sistema a partir de fatos operacionais verificáveis. Descreva serviços, limites, infraestrutura, software, pessoas, procedimentos, dados, compromissos significativos, eventos relevantes, controles aplicáveis, subservice organizations e responsabilidades complementares de user entities.

Use processo controlado de autoria com proprietário, colaboradores, histórico de versões, links de evidência, pontos de revisão e gatilhos de mudança. Reconcilie a descrição com arquitetura, contratos, inventários, políticas, incidentes e evidências operacionais reais.

Chapter 05 — Estrutura dos Trust Services Criteria e mapeamento controlado

Trate os Trust Services Criteria aplicáveis como critérios de asseguarção, não como checklist tecnológico prescritivo. Comece por compromissos, requisitos do sistema, riscos e objetivos de controle e depois mapeie controles implementados aos identificadores aplicáveis usando referências legalmente permitidas.

Mantenha matriz critério-risco-controle com proprietário, atividade, frequência, população, evidência, abordagem de teste, exceções e gatilhos de mudança. Points of focus podem orientar a implementação, mas não devem ser apresentados como controles obrigatórios independentes salvo quando a orientação autorizada assim exigir.

Chapter 06 — Modelo de implementação de Security/common criteria

Construa ambiente integrado de controles de segurança cobrindo governança, avaliação de riscos, comunicação, acesso, operações, monitoramento, mudanças, resposta a incidentes, dependências de fornecedores e ações corretivas.

Para cada controle, documente propósito, proprietário, procedimento, frequência ou gatilho, limite de sistema ou população, fonte de evidência, revisor, caminho de exceção e gatilho de reavaliação.

Chapter 07 — Modelo de implementação de Availability

Quando availability estiver em escopo, traduza compromissos de serviço em controles de capacidade, resiliência, backup, recuperação, monitoramento, incidentes e continuidade. Defina objetivos mensuráveis e dependências que sustentem os compromissos sem prometer garantias não evidenciáveis.

Retenha tendências de capacidade, monitoramento, objetivos de recuperação, evidências de backup, testes de restauração, exercícios de continuidade, incidentes, evidências de nível de serviço e ações corretivas.

Chapter 08 — Modelo de implementação de Processing Integrity

Quando processing integrity for relevante, defina controles que suportem processamento autorizado, completo, preciso, oportuno e válido conforme os compromissos do sistema. Aborde validação de entrada, lógica de processamento, interfaces, tratamento de erros, reconciliação, monitoramento de jobs, transformações de dados, controles de saída e mudanças.

A evidência deve demonstrar população definida, detecção de exceções, reconciliação, correção, autorização, monitoramento e histórico de mudanças.

Chapter 09 — Modelo de implementação de Confidentiality

Identifique informação designada como confidencial por compromissos, contratos, políticas ou necessidade de negócio e mapeie classificação, acesso, transmissão, armazenamento, compartilhamento, retenção e descarte.

Mantenha inventários de dados, regras de classificação, registros de acesso, evidência de criptografia e gestão de chaves quando aplicável, controles de transferência, cronogramas de retenção, descarte, responsabilidades de fornecedores e exceções.

Chapter 10 — Modelo de implementação de Privacy

Quando privacy estiver em escopo, defina governança de informações pessoais durante coleta, aviso, escolha ou consentimento quando aplicável, uso, acesso, divulgação, retenção, correção, exclusão, segurança, qualidade e monitoramento.

Mantenha inventários, avisos, solicitações de titulares, retenção e exclusão, compartilhamentos, governança de processadores e subprocessadores, incidentes, treinamento, reclamações e resultados de monitoramento. Conclusões jurídicas permanecem com profissionais qualificados.

Chapter 11 — Avaliação de riscos e desenho de controles

Opere processo documentado de riscos que considere objetivos, compromissos, ameaças, vulnerabilidades, fraude, mudança tecnológica, terceiros, privacidade, disponibilidade, cadeia de suprimento de software, identidade, dependências operacionais e incidentes anteriores.

Conecte cada risco material a controles ou a decisão explícita de tratamento. Evidencie identificação, análise, justificativa de desenho, aceitação ou remediação, propriedade, prazos, histórico de revisão e mudanças do sistema.

Chapter 12 — Governança e gestão de políticas

Crie estrutura de governança que torne visível a propriedade dos controles e transforme políticas em requisitos operacionais. Cada política ou padrão controlado deve ter proprietário, aprovador, versão, vigência, revisão, distribuição ou treinamento, processo de exceção e controles operacionais mapeados.

Use revisões recorrentes da administração para tratar evidências atrasadas, exceções, incidentes, falhas de controle, mudanças de escopo, problemas de fornecedores e remediações.

Chapter 13 — Acesso lógico e ciclo de vida de identidades

Governe identidades de empregados, contratados, terceiros, privilegiadas, de serviço, de aplicação e de máquina desde a solicitação até a remoção. Defina papéis, menor privilégio, processos de admissão/movimentação/desligamento, aprovações, provisionamento, revisões periódicas e contas inativas.

Mantenha populações completas de sistemas autoritativos de identidade quando possível e vincule solicitações, aprovações, provisionamento, alterações, revisões, remoções e exceções a identidades e períodos específicos.

Chapter 14 — Acesso privilegiado e MFA

Trate acesso privilegiado como domínio de risco separado. Inventarie papéis e contas administrativas, restrinja atribuição, use autenticação forte, controle acesso emergencial, proteja credenciais e segredos, registre atividades privilegiadas e revise direitos e uso.

Evidencie populações de contas, aprovações, configuração de MFA, revisões de acesso, cofres ou gestão de segredos, acessos emergenciais, monitoramento e revogação tempestiva.

Chapter 15 — Operações do sistema e monitoramento

Defina procedimentos para serviços de produção, ferramentas de segurança, jobs, interfaces, capacidade, alertas, incidentes, manutenção e revisão de rotina. Identifique cobertura de monitoramento, proprietários, limites, escalonamento, retenção de evidências e tratamento de falhas.

Retenha painéis ou exportações, registros de alertas ou casos, resultados de jobs, manutenção, tickets, escalonamentos e métricas gerenciais.

Chapter 16 — Gestão de vulnerabilidades e configuração

Mantenha inventários e expectativas aprovadas de configuração para componentes em escopo. Opere descoberta de vulnerabilidades, avaliação, priorização, remediação, exceção, reteste e métricas adequadas ao ambiente.

Vincule achados a ativos, proprietários, decisões de risco, prazos, correções, retestes e exceções. Evidência de configuração deve mostrar baseline

aprovada, estado de implementação, histórico de mudanças, tratamento de drift e verificação periódica.

Chapter 17 — Resposta a incidentes e recuperação

Mantenha programa de resposta a incidentes com severidade, papéis, escalonamento, investigação, contenção, preservação de evidências, comunicações, recuperação, lições aprendidas e ações corretivas.

Teste o plano e retenha cenários, participantes, resultados, lacunas, ações e fechamento. Incidentes materiais devem acionar reavaliação de riscos, controles, descrição do sistema, compromissos, dependências e divulgações do exame.

Chapter 18 — Gestão de mudanças e ciclo de desenvolvimento seguro

Exija autorização rastreável, análise de risco e impacto, testes, revisão, aprovação de implantação, plano de rollback e verificação pós-mudança para alterações materiais. Integre requisitos de segurança, vulnerabilidades, dependências, revisão de código, CI/CD, limites de acesso à produção e mudanças emergenciais.

Evidências podem incluir tickets, pull requests, aprovações, resultados de testes, logs de implantação, releases, revisões emergenciais e controles de segregação de funções.

Chapter 19 — Logging, alertas e retenção de evidências

Defina sistemas e atividades que exigem logs, alertas, trilhas de auditoria e evidências retidas. Estabeleça coleta, sincronização de tempo, acesso, retenção, revisão, escalonamento e integridade conforme risco e necessidade do trabalho.

Mantenha inventários de fontes, configurações de retenção, logs representativos, casos de alerta, revisões, acessos e exceções. Repositórios de evidência devem proteger informação confidencial e preservar proveniência.

Chapter 20 — Backup, resiliência e monitoramento de disponibilidade

Defina escopo, frequência, proteção, retenção, testes de restauração, mecanismos de resiliência, dependências e monitoramento operacional. Alinhe o desenho de recuperação aos compromissos de serviço e impacto de negócio.

Retenha populações de jobs de backup, falhas, testes de restauração, exercícios de failover, monitoramento de capacidade e disponibilidade, ações de recuperação e remediação.

Chapter 21 — Governança de fornecedores e subservice organizations

Inventarie terceiros e subservice organizations que hospedem, processem, suportem, protejam ou afetem materialmente o sistema. Defina due diligence, classificação de risco, contratos, responsabilidades, revisão de asseguarção, monitoramento, incidentes, mudanças e encerramento.

Retenha contratos e termos de segurança, due diligence, relatórios de asseguarção, atualizações relevantes, achados, responsabilidades complementares, mudanças de serviço, incidentes e remediação.

Chapter 22 — Complementary user-entity controls

Identifique controles ou responsabilidades que user entities devem executar para que controles e compromissos da organização de serviços operem como pretendido. Vincule cada responsabilidade ao limite do serviço, mecanismo de comunicação e premissa correspondente.

A administração deve assegurar descrição e comunicação adequadas e não usar esses controles para transferir responsabilidades que pertencem à própria organização de serviços.

Chapter 23 — Nuvem e responsabilidade compartilhada

Mapeie serviços em nuvem, plataformas gerenciadas, SaaS, controles herdados, controles configurados pelo cliente, identidades, logging, gestão de chaves, limites de rede, localizações de dados e responsabilidades de fornecedores.

Use relatórios de asseguarção do provedor como entradas de evidência, não como prova automática de que a configuração da organização é eficaz.

Retenha inventários, matrizes de responsabilidade, configurações, revisões de assegurarão, exceções e gatilhos de mudança.

Chapter 24 — Operações de privacidade e ciclo de vida de dados

Operacionalize governança de dados pessoais por meio de inventários, mapeamento de finalidade e compromissos, acesso, retenção, exclusão, compartilhamento, atendimento de solicitações, incidentes, fornecedores e monitoramento.

As evidências devem ser baseadas em população quando possível e mostrar tempestividade, aprovações, resultados, exceções e ações corretivas. Separe conclusões legais da prontidão SOC 2.

Chapter 25 — População de evidências e prontidão para amostragem

Para controles recorrentes, preserve populações completas e reproduzíveis de fontes autoritativas. Defina geração, reconciliação, proteção e vínculo ao período do exame. Evite listas manuais que excluam falhas ou não tenham proveniência.

Cada objeto de evidência deve identificar sistema fonte, método de consulta ou relatório, proprietário, período, tamanho da população, contexto de seleção, artefato, revisor e exceções. Decisões de amostragem pertencem ao profissional independente.

Chapter 26 — Prontidão Type 1 versus Type 2

Um modelo Type 1 foca se os controles estão adequadamente desenhados e implementados em uma data específica. Um modelo Type 2 também precisa sustentar evidências de operação durante o período relevante.

Para Type 2, estabeleça calendários de evidência antes do período, preserve populações recorrentes, monitore atividades perdidas e remedeie cedo. Não recrie evidências de forma que deturpe quando ou como o controle operou.

Chapter 27 — Governança de exceções, desvios e remediação

Defina como exceções de controle, lacunas de evidência, desvios, incidentes e achados são registrados, avaliados, atribuídos, remediados, retestados e

escalados. Diferencie lacunas documentais de falhas de desenho ou operação com base em evidência.

Mantenha identificador, controles ou populações afetadas, impacto, causa raiz quando aplicável, proprietário, prazo, tratamento temporário, evidência de remediação, reteste, recorrência e decisões gerenciais.

Chapter 28 — Revisão da administração e monitoramento contínuo

Opere revisão gerencial ao longo do ano usando indicadores de saúde de controles, conclusão de evidências, idade de exceções, incidentes, mudanças de fornecedores, revisões de acesso, vulnerabilidades, testes de recuperação, políticas e mudanças do sistema.

Retenha atas ou aprovações equivalentes, painéis, exceções, decisões, aceitações de risco, compromissos de remediação e evidências de acompanhamento.

Chapter 29 — Interação com auditor e gestão de solicitações

Selecione firma de CPA independente adequadamente qualificada e estabeleça comunicação controlada, transferência de evidências, rastreamento de solicitações, marcos, discussões de escopo, escalonamento e confidencialidade.

Mantenha log de solicitações com proprietário, prazo, artefato, status, perguntas, follow-up e resolução. Equipes de prontidão podem organizar evidências, mas não dirigir procedimentos ou conclusões do profissional independente.

Chapter 30 — Leitura do relatório, qualificações e achados

Prepare administração e usuários autorizados para ler o relatório considerando escopo, critérios ou categorias, período ou data, tratamento de subservice organizations, complementary user-entity controls, testes, exceções, respostas da administração e qualificações ou limitações.

Rastreie achados até remediação e reavaliação. Declarações externas sobre status SOC 2 devem ser atuais, precisas e nunca sugerir certificação ou asseguaração mais ampla do que o relatório oferece.

Chapter 31 — Conformidade contínua e gatilhos de mudança

Mantenha prontidão entre exames por meio de operação recorrente de controles, coleta de evidências, revisão de riscos, monitoramento de fornecedores, governança de acesso, vulnerabilidades/configuração, testes de recuperação, revisão de políticas e remediação.

Gatilhos incluem aquisições, novos produtos, migrações de nuvem, redesenho de autenticação, novos processadores, incidentes significativos, indisponibilidades materiais, novos compromissos, mudanças de arquitetura e automação de controles.

Chapter 32 — Release, reavaliação e ciclo de vida das evidências

Antes de tratar o manual controlado como pronto para publicação, verifique o estado autoritativo das fontes AICPA, confirme o master inglês exato, derive as edições controladas es-419 e pt-BR, execute QA estrutural, de copyright, terminologia e paridade, gere candidatos DOCX/PDF exatos, execute QA renderizado de acessibilidade/visual/conteúdo, faça staging durável dos binários, registre proveniência SHA-256, reconcilie metadados de ciclo de vida e confirme a publicação do predecessor.

Para uso organizacional, defina retenção de evidências, confidencialidade, transferência segura, versionamento, substituição e regras de reavaliação. Não publique evidências confidenciais de clientes, dados de empregados, segredos, screenshots de produção ou workpapers restritos em exemplos públicos.

Referências autoritativas

- Superfície de recursos SOC 2 da AICPA & CIMA.
- 2017 Trust Services Criteria (With Revised Points of Focus — 2022), usados somente como referência autoritativa dos critérios e não reproduzidos neste manual.
- 2018 SOC 2 Description Criteria (With Revised Implementation Guidance — 2022), usados somente como referência autoritativa da descrição e não reproduzidos neste manual.
- SOC for Service Organizations Engagements — Overview da AICPA & CIMA, atualizado em 23 de abril de 2026.

A verificação das fontes no momento do release continua obrigatória porque padrões e orientações autoritativas podem mudar.